

Princípios de Segurança da Informação: Framework Revisado

Baseado no artigo de Teixeira e Sá-Soares (2013)

"A Revised Framework of Information Security Principles"

2.1 A Tríade Tradicional

Confidencialidade

Características históricas: A confidencialidade é um dos três princípios básicos e tradicionais da InfoSec, provavelmente o mais facilmente e frequentemente associado com segurança[1].

Historicamente, tem raízes militares e foi o primeiro princípio formalizado num documento seminal InfoSec – o TCSEC (Trusted Computer System Evaluation Criteria), baseado no modelo Bell-LaPadula[1].

Análise das definições: Este é o princípio que lida com o sigilo, cobrindo informação no armazenamento, durante processamento e enquanto em trânsito[1]. Em termos de âmbito, mais de metade das definições para confidencialidade são apresentadas no contexto de InfoSec, com ênfase na gestão e governança de InfoSec e nos princípios e diretrizes de InfoSec[1]. Relativamente à natureza do conceito, não há tendência clara, embora objetivo, característica e princípio se destaquem[1].

Propósito e observações: O propósito da confidencialidade é, segundo a maioria dos autores, não divulgar, não tornar disponível e não permitir acesso à informação por entidades não autorizadas ou pessoas ou de formas não autorizadas[1]. Autores como Parker (1998) e Pfleeger e Pfleeger (2003) chamaram atenção para o facto de a confidencialidade não dever ter como única preocupação a divulgação de informação (secreta), mas também observação voluntária ou involuntária, impressão ou simplesmente saber que um ativo particular de informação existe[1].

Integridade

Formação histórica: O princípio da integridade é também parte do modelo tradicional de InfoSec[1]. Para o público geral, contudo, é provavelmente menos notável que a confidencialidade. Seguiu a confidencialidade em termos de formalização, transmitida no modelo Biba[1].

Conceito subjacente: Subjacente ao conceito de integridade está a noção de mudança, com a maioria das definições abordando o acesso aos recursos de informação e o processo de autorização associado[1].

Dois correntes distintas: Considerando o propósito da integridade, há duas grandes correntes distintas[1]. Por um lado, o princípio da integridade garante que a informação seja completa, precisa e correta. Por outro lado, a integridade refere-se à prevenção de manipulação, modificação e destruição não autorizadas[1].

Dimensão contextual e comportamental: Uma questão relevante associada com integridade é a sua dimensão contextual e comportamental[1]. A definição fornecida pelo ITGI (2007) salienta que a precisão, completude e validade da informação devem ser julgadas de acordo com os valores e expectativas do negócio[1]. O impacto da interpretação da informação pelas pessoas na integridade já tinha sido sublinhado por Dhillon e Backhouse (2000), que argumentaram pela necessidade dos utilizadores terem capacidade de interpretar informação de acordo com as regras de negócio da organização a que pertencem[1].

Disponibilidade

Visibilidade para utilizadores: A disponibilidade é o terceiro componente do modelo tradicional para InfoSec[1]. Provavelmente, é o princípio cujo comprometimento é mais imediatamente evidente para os utilizadores[1].

Distinções importantes: É relevante distinguir entre definições com foco na informação e nos sistemas, embora o seu significado seja muito próximo[1]. Uma questão importante relaciona-se com o acesso e possibilidade de usar informação e sistemas de forma oportuna[1]. Contudo, e em contraste com os dois princípios anteriores, a preocupação com acesso não é unicamente colocada na sua restrição, mas a principal preocupação é ser capaz de conceder acesso àqueles com direito a ele[1].

Acesso vs. Usabilidade: Embora o acesso à informação seja importante, a definição avançada pelas normas ISO sugere que ser capaz de aceder à informação não implica que a informação seja utilizável[1]. A usabilidade da informação já tinha sido notada por Parker (1998) e elaborada por Whitman e Mattord, que qualificam acesso em termos de autorização, formato e obstrução[1].

Questão temporal: Uma nota final diz respeito à questão temporal apontada por Posthumus e von Solms (2004)[1]. Não só pode haver um momento certo para tornar informação disponível, mas também a disponibilidade é sempre testada num momento específico do tempo[1].

2.2 Extensões da Tríade

Privacidade

Relação com confidencialidade: A privacidade é um dos tópicos mais discutidos no campo da InfoSec e provavelmente um dos mais facilmente entendidos pela sociedade em geral[1]. Este é um conceito intimamente relacionado com o conceito de confidencialidade[1].

Diferentes perspetivas: Relativamente ao propósito, há dois sentidos distintos[1]. Um tem a ver com controlo da informação pessoal detida por terceiros, incluindo controlo sobre a divulgação dessa informação, e o outro diz respeito à não intrusão, anonimato, não ligação, não detetabilidade e não observabilidade[1].

Clarificações conceituais: Pfizmann e Hansen (2010) propuseram e caracterizaram estes últimos termos para uma melhor compreensão do conceito de privacidade[1]: anonimato – um sujeito não é identificável dentro de um conjunto de sujeitos; não ligação – não é possível distinguir suficientemente se um item de interesse está ligado a outro(s) item(s) de interesse; não

detetabilidade – não é possível distinguir suficientemente se um item de interesse existe ou não; e não observabilidade – refere-se ao anonimato de um item de interesse ou à não detetabilidade de um sujeito[1].

Fiabilidade

Foco em sistemas: O princípio da fiabilidade, ao contrário dos princípios anteriormente revistos, é principalmente proposto no domínio dos sistemas em vez da informação[1]. Tanto documentos ITGI como ISO não associam fiabilidade diretamente à segurança da informação[1].

Continuidade de serviço: O objeto que é principalmente visado pelas definições é o sistema, com o propósito do princípio sendo a continuidade da entrega de serviços ou o funcionamento sem falhas de um sistema[1]. Na realidade, Trivedi et al. (2009) sugerem que a fiabilidade pode ser conceituada como uma medida da continuidade de serviço[1].

Autenticidade

Aplicabilidade: Em contraste com a fiabilidade, o princípio da autenticidade é aplicável à própria informação[1]. É também frequentemente aplicado a processos e pessoas[1].

Distinção da integridade: À primeira vista, há um certo grau de sobreposição entre autenticidade e integridade[1]. Provavelmente, um dos principais apoiadores da distinção entre os dois princípios é Parker (1998)[1]. Este autor propôs um par de princípios formados por integridade e autenticidade, no qual o primeiro se relaciona com completude, e o segundo com validade[1]. Segundo a sua perspetiva, uma entidade é autêntica se representa os factos desejados e a realidade[1].

Exemplo ilustrativo: Parker exemplifica com um cenário no qual um distribuidor de software obteve um programa de jogo de computador de um editor obscuro[1]. O distribuidor modificou o nome do editor nos ecrãs de média e título para o de um editor bem conhecido e depois fez cópias do média[1]. Sem informar qualquer editor, o distribuidor disseminou cópias do programa num país estrangeiro[1]. Parker observa que o programa tinha integridade porque identificava um editor e estava completo e sólido[1]. Contudo, não era um jogo autêntico do editor bem conhecido, i.e., não se conformava à realidade pois deturpava o editor do jogo[1].

Não-Repúdio

Papel central nas comunicações: O não-repúdio partilha algumas das características da autenticidade[1]. Este princípio desempenha um papel central na segurança das comunicações, onde é importante provar que uma mensagem originou de um remetente específico (não-repúdio de origem) e que uma mensagem foi aceite por um recetor específico (não-repúdio de receção)[1].

Capacidade essencial: O ponto essencial deste conceito repousa na capacidade de garantir que um certo evento ocorreu ou não ocorreu e, no primeiro caso, ser capaz de identificar as entidades envolvidas[1]. Por outras palavras, todas as ações relevantes para InfoSec feitas num sistema são conhecidas e não podem ser negadas ou escondidas pelos seus autores[1].

Importância do inverso: Uma observação final diz respeito à importância do inverso da repudição[1]. Além de ter a capacidade de demonstrar que um certo agente realmente fez certas

transações mesmo quando o agente nega, é também importante ser capaz de demonstrar que um certo agente não realizou certas ações mesmo se o agente afirma ter feito tais transações[1].

Accountability (Responsabilização)

Foco nas pessoas: A accountability é apresentada por diversos autores como um princípio InfoSec, apesar de não se aplicar diretamente à informação em si, mas às pessoas que manipulam informação[1].

Semelhanças com não-repúdio: Nas definições analisadas é imediatamente reconhecível alguns paralelos entre as definições de não-repúdio e accountability, especialmente em aspetos relacionados com a identidade ou identificação de pessoas[1]. O propósito da accountability partilha semelhanças com o propósito do não-repúdio, em que ambos procuram atribuir responsabilidade por eventos ou ações a uma dada entidade[1].

Distinções contextuais: No domínio da dependabilidade, o não-repúdio é geralmente aplicado à transmissão de mensagens, enquanto accountability é aplicada à identidade das pessoas[1]. A principal preocupação, contudo, é ser capaz de atribuir e imputar a uma entidade específica as consequências de uma certa ação ou decisão que foi prejudicial à segurança dos SI[1].

Segurança (Safety)

Foco em consequências catastróficas: Nas definições analisadas, safety é usado no domínio dos sistemas, e há consenso significativo relativamente ao propósito deste princípio, nomeadamente a ausência de consequências catastróficas no ambiente e pessoas[1]. Ao centrar o conceito nos efeitos do mau comportamento dos sistemas, os proponentes classificam consequências como catastróficas, circunscrevendo o conceito às situações onde os resultados excedem um certo limiar[1].

Sobrevivabilidade

Capacidade dos sistemas: Como no caso de outros conceitos já revistos, a sobrevivabilidade é apresentada não como um princípio aplicado diretamente à informação, mas aplicado a sistemas em geral[1]. O objeto focado pelas definições é o sistema (computadores e redes)[1]. Relativamente à natureza, a sobrevivabilidade é geralmente apresentada como uma capacidade do sistema, cujo propósito é manter operação mesmo na presença de falhas ou ataques[1].

Relacionamento com resiliência: Este princípio está inter-relacionado com o traço de resiliência dos sistemas, entendido como a capacidade de responder e recuperar rapidamente de situações de crise[1]. Para sobreviver, um sistema precisa de se adaptar às condições em mudança do seu ambiente (ataques, falhas e acidentes) para que a restauração de um nível mínimo de serviço seja atingível[1].

Utilidade

Framework de Parker: No campo da InfoSec, o princípio da utilidade aparece no framework proposto por Parker (1998)[1]. Parker articula o princípio da utilidade com o princípio da disponibilidade, relacionando o primeiro com a utilidade da informação e o segundo com a usabilidade da informação[1].

Distinção da disponibilidade: Para ilustrar a diferença entre esses princípios, Parker delinea um cenário onde um empregado que rotineiramente encripta a única cópia de informação valiosa armazenada no seu computador, acidentalmente apaga a chave de encriptação do ficheiro[1]. Neste caso, a disponibilidade da informação é mantida, mas a sua utilidade é perdida[1].

Propósito específico: Ao indexar a utilidade da informação a um propósito específico, Parker traz para o domínio da InfoSec preocupações sobre o grau de utilidade da informação para a tarefa que os utilizadores têm em mãos[1].

Precisão

Modelo expandido: O conceito de precisão é usado em muitos contextos variados[1]. No campo da InfoSec foi introduzido por Whitman e Mattord (2011) no seu modelo expandido de características críticas da informação[1].

Combinação de liberdade de erros: Whitman e Mattord (2011) combinam no princípio da precisão da informação a liberdade de erros e falhas e a existência do valor que o utilizador final espera, argumentando que se a informação foi modificada, intencionalmente ou não intencionalmente, já não é precisa[1].

Distinção da integridade: À primeira vista, este entendimento aproxima-se da definição de integridade[1]. Contudo, se considerarmos os exemplos fornecidos por esses autores somos capazes de clarificar o significado de precisão[1]. Em contraste com as definições de integridade, ambas as situações descritas para o exemplo da conta corrente diferem do facto de os agentes (caixa do banco e titular da conta) estarem autorizados a alterar a informação, contudo, modificam-na para um valor incorreto[1].

Posse

Modelo expandido de Parker: O princípio da posse da informação é parte do modelo InfoSec expandido proposto por Parker (1998)[1]. Whitman e Mattord (2011) também incluíram este princípio no seu modelo InfoSec[1].

Aspeto de controlo: A partir destas definições, é salientado o aspeto do controlo da informação[1]. Hoje em dia, parece consensualmente aceite que propriedade e controlo da informação são talvez as fontes mais importantes de poder nas organizações[1].

Justificação de Parker: Parker (1998) justifica a adição deste princípio ao modelo tradicional para que os esforços InfoSec possam prevenir certos tipos de perdas, como roubo de informação[1]. O racional delineado por esse autor é clarificado contrastando entre posse e confidencialidade[1]. Por definição, o princípio da posse lida apenas com o que as pessoas possuem e sabem, não com o que possuem sem saber[1].

Diferentes graus de controlo: Uma vez que é geralmente extremamente simples e barato produzir cópias adicionais de informação, podemos ter diferentes graus de controlo relativamente à informação que possuímos[1]. Este será o caso de ter posse exclusiva ou partilhada de informação, bem como ser capaz de recuperar propriedade após perda temporária de posse[1].

2.3 Complementos à Tríade - Modelo RITE

Nesta secção revisam-se quatro princípios propostos por Dhillon e Backhouse (2000) que constituem uma clara partida da tríade CIA[1]. Em vez de restringir a sua atenção à informação armazenada ou em trânsito em processadores de silício (computadores e redes), esses autores focaram os desafios de segurança colocados e enfrentados por processadores biológicos de informação (pessoas)[1].

Os Quatro Princípios RITE:

Responsabilidade: Contrastando com accountability, este princípio refere-se à responsabilidade que cada membro de uma organização deve observar ao desempenhar a sua função[1]. Com o desaparecimento das estruturas de gestão vertical, uma perceção clara da responsabilidade pessoal e saber que papéis desempenhar dentro da organização tornam-se cada vez mais importantes[1]. A relevância da responsabilidade é mais aguda quando surgem novas circunstâncias na organização e torna-se necessário alguém assumir voluntariamente a responsabilidade para lidar com essas mesmas circunstâncias[1].

Integridade (pessoal): Nas organizações de hoje a informação é um dos ativos mais valiosos, contudo, é um ativo que por sua natureza pode ser facilmente divulgado a partes não autorizadas[1]. A este respeito a integridade pessoal é de particular importância[1]. Embora a designação deste princípio seja a mesma que compõe a tríade CIA, neste contexto a integridade está ligada à lealdade dos membros da organização[1].

Confiança: A confiança, em oposição ao controlo externo, é de particular importância em organizações geograficamente difusas onde os membros não podem controlar uns aos outros e "supervisão física" não é uma opção[1]. Neste contexto espera-se que cada membro atue de acordo com as normas e padrões de comportamento aceites e implementados pela organização[1].

Eticidade: Este princípio advoga que os membros de uma organização devem adotar comportamentos éticos mesmo se estes não estão formalmente definidos e implementados[1]. Lida essencialmente com as relações informais que se estabelecem dentro da organização e com comportamento em situações novas sem regras pré-definidas[1].

Tabela 16: Framework Revisado de Princípios de Segurança da Informação

DIMENSÃO "TO KNOW" (SABER)

Relaciona-se com o valor intrínseco da informação, ou seja, seu conteúdo e significado

Princípio	Definição Adotada
Confidentiality	Information is only disclosed or observed by individuals, entities, and processes authorized by its owner
Privacy (<i>sub-princípio</i>)	Information to identify, detect, associate, or track an individual is only disclosed or observed by individuals, entities, and processes authorized by that individual or designated by law
Possession	Information is held and controlled by its owner or by individuals, entities, and processes authorized by him

DIMENSÃO "TO CHANGE" (MUDAR)

Foca-se primariamente em ações que resultam na modificação e manipulação da informação

Princípio	Definição Adotada
Integrity	Information and systems are modified in an authorized manner only by individuals, entities, and processes authorized by the owner of those assets
Authenticity	Information is in accordance with a particular reality, and its genuineness and validity are verifiable, or an individual, entity, or process is who it claims to be
Accuracy	Information is free from errors, flaws, and omissions

DIMENSÃO "TO USE" (UTILIZAR)

Relaciona-se diretamente com a capacidade de usar informação ou os sistemas que a suportam

Princípio	Definição Adotada
Availability	Information and the systems that support it are usable whenever required by individuals, entities, or processes authorized by their owners
Reliability (sub-princípio)	System performs its function without failure during a determined period of time
Survivability (sub-princípio)	System delivers essential services in the presence of attacks, failures, or accidents
Utility	Information or systems can be used to serve a given purpose defined by their owners

DIMENSÃO "TO COMPLY" (CUMPRIR)

Aborda necessidades de procedimentos de controlo e conformidade regulamentar

Princípio	Definição Adotada
Traceability	Actions relevant to InfoSec are demonstrable and imputable to their authors
Non-Repudiation (sub-princípio)	Actions relevant to InfoSec are known and cannot be denied or hidden by their authors, or unjustifiably alleged as executed by some agent
Accountability (sub-princípio)	Actions relevant to InfoSec are attributable to the individuals responsible for those actions
Legality	Procedures related to InfoSec comply with applicable laws, statutes, regulations, and contractual obligations, safeguarding the organization's responsibility on a civil and criminal basis

DIMENSÃO "TO BE" (SER)

Aborda o que os membros de uma organização devem ser dentro dessa organização

Princípio	Definição Adotada
Responsibility	Each member of an organization has a clear understanding of their roles and responsibilities, assuming ad hoc responsibilities when new developments require it
Integrity (personal)	Each member of an organization is loyal to the organization and remains so
Trust	Each member of an organization behaves according to the norms and behavioral standards accepted and agreed upon by the organization
Ethics	Each member of an organization adopts ethical behavior even if ethical practices are not formalized or declared

Conclusão

Este framework revisado representa uma evolução significativa do modelo CIA tradicional, organizando **13 princípios principais e 5 sub-princípios** em **5 dimensões** distintas. A proposta oferece uma abordagem mais holística e abrangente para a gestão moderna da segurança da informação, integrando aspectos técnicos, legais, comportamentais e organizacionais.

O framework não apenas expande os princípios tradicionais, mas também introduz dimensões humanas e de conformidade que são essenciais no contexto atual da segurança da informação, proporcionando uma base mais sólida e atual para as organizações protegerem seus ativos informacionais.

Referências

[1] Teixeira, A. and F. de Sá-Soares (2013). A Revised Framework of Information Security Principles. In Furnell, S. M., N. L. Clarke and V. Katos (Eds.), Proceedings of the European Information Security Multi-Conference EISMC 2013—IFIP Information Security Management Workshop. Lisbon (Portugal).